W10D4 **26-2-2026**
Luca Danisi

🔐 Penetration Test – Fase di Information Gathering

Cliente: Ambiente di test interno alla Virtual Box
Target: **192.168.50.101**
Macchina utilizzata: Virtual Machine KALI
IP: **192.168.50.100**

1. Obiettivo

Identificare:

- Stato dell'host
- Servizi esposti
- Versioni software
- Potenziali superfici di attacco

L'attività si è limitata alla fase di raccolta informazioni, senza tentativi di exploit.

---

2. Metodologia

È stato adottato un approccio progressivo, utilizzando i seguenti comandi :

A – STATO DELL HOST *“nmap -sn PE 192.168.50.101”* – In questo modo verifichiamo se l Host Metasploitable è raggiungibile con un ICMP (ping).

```
└─$ nmap -sn -PE 192.168.50.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-27 02:41 -0500
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or spe
cify valid servers with --dns-servers
Nmap scan report for 192.168.50.101
Host is up (0.0014s latency).
MAC Address: 08:00:27:2D:C2:F8 (Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 0.11 seconds
```

Analisi dell OUTPUT : *Come vediamo dal risultato del nostro comando, la macchina di metasploitable è* ***raggiungibile*** *il tempo di latenza molto breve ci conferma di essere su una* ***rete interna*** *e ci fornisce anche il* ***MAC address,*** *inoltre il PING* ***conferma l assenza di firewall.***

Come verifica incrociata, qualora il PING non fosse passato per l esistenza di un firewall, facciamo una verifica con **ARP discovery**, e otterremo lo stesso risultato.

- VERIFICA INCROCIATA *“Netdiscover -r 192.168.50.0/24”*

```
Currently scanning: Finished!   |   Screen View: Unique Hosts

1 Captured ARP Req/Rep packets, from 1 hosts.   Total size: 60
_____________________________________________________________________________
  IP            At MAC Address     Count     Len  MAC Vendor / Hostname
_____________________________________________________________________________
192.168.50.101  08:00:27:2d:c2:f8      1      60  PCS Systemtechnik GmbH
```

B – SERVIZI ESPOSTI *“NMAP -sV 192.168.50.101” – in questo modo verifichiamo non solo quali porte e servizi sono aperti e disponibili su metasploitable, ma anche quale versione software viene usata.*

```
└─$ nmap -sV 192.168.50.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-27 03:09 -0500
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or spe
cify valid servers with --dns-servers
Nmap scan report for 192.168.50.101
Host is up (0.0022s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login?
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:2D:C2:F8 (Oracle VirtualBox virtual NIC)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:
linux_kernel
```

Servizi Esposti Rilevati e Versioni Software

Sono stati identificati i seguenti servizi principali

Porta	Servizio	Versione	Note
21	FTP	vsftpd 2.3.4	Versione obsoleta
22	SSH	OpenSSH 4.7p1	Versione datata
23	Telnet	Linux telnetd	Protocollo non cifrato
25	SMTP	Postfix	Possibile user enumeration
53	DNS	BIND 9.4.2	Versione obsoleta
80	HTTP	Apache 2.2.8	Versione vulnerabile
139/445	SMB	Samba 3.x–4.x	SMBv1 attivo
3306	MySQL	5.0.51a	DB esposto
5432	PostgreSQL	8.3.x	DB esposto
5900	VNC	Protocol 3.3	Accesso remoto
8180	Tomcat	JSP Engine 1.1	Application server

*Con il comando **“crackmapexec”** potremmo approfondire alcuni applicativi specfici, e ottenere ulteriori informazioni.*

COMANDO CRACKMAPEX per gli applicativi specifici:

```
┌──(kali㉿kali)-[~]
└─$ crackmapexec smb 192.168.50.101
SMB         192.168.50.101  445    METASPLOITABLE   [*] Unix (name:METASPLOITABLE) (domain:localdomain) (signing:False) (SMBv
1:True)

┌──(kali㉿kali)-[~]
└─$ crackmapexec ftp 192.168.50.101
FTP         192.168.50.101  21     192.168.50.101   [*] Banner: (vsFTPd 2.3.4)

┌──(kali㉿kali)-[~]
└─$ crackmapexec ssh 192.168.50.101
SSH         192.168.50.101  22     192.168.50.101   [*] SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
```

Analisi Preliminare del Rischio

Dopo aver identificato le vulnerabilità, facciamo un Risk Assessment, in modo da avere un quadro chiaro delle priorità su cui intervenire

Livello	PORTA	Servizio	MOTIVAZIONE
ALTO	21	FTP	***Vulnerabilià nota vsftpd 2.3.4 + accesso remoto diretto***
ALTO	139/445	SMB	***Un attaccante potrebbe prendere il controllo della macchina, causa vecchia versione software***
ALTO	23	TELNET	***Le password viaggiano in chiaro, dando accesso remoto alla macchina***
ALTO	8180	TOMCAT	***Versione vecchia da accesso ad applicativi con potenziale controllo della macchina***
MEDIO	80	APACHE	***Molto vecchio, possibilità di entrare nel sistema***
MEDIO	3306	MYSQL	***Possibile furto informazioni***
MEDIO	5432	POSTGRESQL	***Possibile furto informazioni***
MEDIO	5900	VNC	***Se protetto male la macchina può essere controllata a distanza***
MEDIO	53	BIND DNS	***Può essere usato per manipolare traffico e raccogliere informazioni***
BASSO	22	SSH	***Pericoloso se psw deboli***
BASSO	25	SMTP	***Eventuale accesso a informazioni***

Esercizio facoltativo

Cerchiamo di verificare come risponde la macchina a uno scan normale, e successivamente proveremo in modi alternativi per interpretare come la macchina risponde e/o se è presente qualche firewall. Come vediamo dalla schermata qui sotto con **“ACK”** la metasploitable risponde **“SYN”**, possiamo considerarla una comunicazione aperta e standard.

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sS -sV --reason -oN step1_baseline.txt 192.168.50.101
[sudo] password for kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-27 04:31 -0500
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid serv
ers with --dns-servers
Nmap scan report for 192.168.50.101
Host is up, received arp-response (0.00057s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     REASON         VERSION
21/tcp   open  ftp         syn-ack ttl 64 vsftpd 2.3.4
22/tcp   open  ssh         syn-ack ttl 64 OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
```

A questo punto proviamo a fare un **Fin scan**, ovvero comunichiamo semplicemente che la nostra comunicazione è finita per verificare che tipo di risposta ci darà. Come vediamo dalla schermata , la metasploitable non è stata in grado di darci una “reason” ma ci ha comunque comunicato la lista di porte aperte.

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sF --reason -oN step2_fin.txt  192.168.50.101
[sudo] password for kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-27 04:41 -0500
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers wi
rs
Nmap scan report for 192.168.50.101
Host is up, received arp-response (0.00057s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE         SERVICE      REASON
21/tcp   open|filtered ftp          no-response
22/tcp   open|filtered ssh          no-response
23/tcp   open|filtered telnet       no-response
```

Con questi comandi abbiamo potuto verificare che la nostra metasploitable non ha un firewall e quindi la comunicazione avrà sempre un ritorno positivo.

DECONY SCAN

Nel nostro laboratorio, non avremo risultati differenti dai precedenti perché la macchina essendo priva di firewall rende di fatto non necessarie queste tecniche di scan. In ogni caso come richiesto dall esercizio spiegheremo il comando e quali potrebbero essere le conseguenze in un ambiente macchina diverso.

- DECOY: Con questo metodo si effettua uno scan simulando più richieste da IP differenti, in modo tale che la macchina non sarà in grado di riconoscere qual' è il vero scanner. Nel nostro caso utilizzeremo wireshark per vedere come il decoy è stato effettuato con successo.

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sS -D 192.168.50.200,192.168.50.201,ME 192.168.50.101
```

30	0.070847…	192.168.50.200	192.168.50.101	TCP	58	50013 → 445 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
31	0.070869…	192.168.50.201	192.168.50.101	TCP	58	50013 → 445 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
32	0.070891…	192.168.50.100	192.168.50.101	TCP	58	50013 → 445 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
33	0.070923…	192.168.50.101	192.168.50.100	TCP	60	1723 → 50013 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0

Come possiamo notare solo la connessione proveniente dal nostro ip .100 chiude la connessione con l "ack", gli altri IP di decoy non riescono a farlo.

FRAMMENTAZIONE

Con questo tipo di comando possiamo dividere un trasmissione in frammenti diversi, e *in questo modo la comunicazione tra macchine ha risultati diversi. Infatti spesso si usa questo metodo per scavalcare eventuali filtri del firewall.*

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sS -f 192.168.50.101
```

Come possiamo vedere dalla schermata di wireshark, i dati vengono prima frammentati e poi riassemblati mantenendo sempre il loro # ID univoco.

ip.addr == 192.168.50.101S

No.	Time	Source	Destination	Protocc	Lengt	Info
3993	0.603934…	192.168.50.100	192.168.50.101	IPv4	42	Fragmented IP protocol (proto=TCP 6, off=0, ID=eb7b) [Reassembled in #3995]
3994	0.604052…	192.168.50.100	192.168.50.101	IPv4	42	Fragmented IP protocol (proto=TCP 6, off=8, ID=eb7b) [Reassembled in #3995]
3995	0.604171…	192.168.50.100	192.168.50.101	TCP	42	33033 → 1001 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
3996	0.604295…	192.168.50.100	192.168.50.101	IPv4	42	Fragmented IP protocol (proto=TCP 6, off=0, ID=e2f5) [Reassembled in #3999]
3997	0.604403…	192.168.50.101	192.168.50.100	TCP	60	6699 → 33033 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
3998	0.604445…	192.168.50.100	192.168.50.101	IPv4	42	Fragmented IP protocol (proto=TCP 6, off=8, ID=e2f5) [Reassembled in #3999]
3999	0.604575…	192.168.50.100	192.168.50.101	TCP	42	33033 → 1105 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
4000	0.604715…	192.168.50.101	192.168.50.100	TCP	60	1001 → 33033 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
4001	0.604758…	192.168.50.100	192.168.50.101	IPv4	42	Fragmented IP protocol (proto=TCP 6, off=0, ID=c4a9) [Reassembled in #4004]
4002	0.604857…	192.168.50.101	192.168.50.100	TCP	60	1105 → 33033 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
4003	0.605033…	192.168.50.100	192.168.50.101	IPv4	42	Fragmented IP protocol (proto=TCP 6, off=8, ID=c4a9) [Reassembled in #4004]
4004	0.605152…	192.168.50.100	192.168.50.101	TCP	42	33033 → 2065 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
4005	0.605271…	192.168.50.100	192.168.50.101	IPv4	42	Fragmented IP protocol (proto=TCP 6, off=0, ID=fdfb) [Reassembled in #4007]
4006	0.605388…	192.168.50.100	192.168.50.101	IPv4	42	Fragmented IP protocol (proto=TCP 6, off=8, ID=fdfb) [Reassembled in #4007]
4007	0.605505…	192.168.50.100	192.168.50.101	TCP	42	33033 → 3011 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
4008	0.605623…	192.168.50.100	192.168.50.101	IPv4	42	Fragmented IP protocol (proto=TCP 6, off=0, ID=13ff) [Reassembled in #4010]
4009	0.605740…	192.168.50.100	192.168.50.101	IPv4	42	Fragmented IP protocol (proto=TCP 6, off=8, ID=13ff) [Reassembled in #4010]
4010	0.605876…	192.168.50.100	192.168.50.101	TCP	42	33033 → 3809 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
4011	0.605996…	192.168.50.100	192.168.50.101	IPv4	42	Fragmented IP protocol (proto=TCP 6, off=0, ID=4480) [Reassembled in #4014]
4012	0.606113…	192.168.50.100	192.168.50.101	IPv4	42	Fragmented IP protocol (proto=TCP 6, off=8, ID=4480) [Reassembled in #4014]
4013	0.606212…	192.168.50.101	192.168.50.100	TCP	60	2065 → 33033 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
4014	0.606250…	192.168.50.100	192.168.50.101	TCP	42	33033 → 2135 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
4015	0.606367…	192.168.50.100	192.168.50.101	IPv4	42	Fragmented IP protocol (proto=TCP 6, off=0, ID=0cda) [Reassembled in #4018]
4016	0.606561…	192.168.50.101	192.168.50.100	TCP	60	3011 → 33033 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
4017	0.606598…	192.168.50.100	192.168.50.101	IPv4	42	Fragmented IP protocol (proto=TCP 6, off=8, ID=0cda) [Reassembled in #4018]
4018	0.606714…	192.168.50.100	192.168.50.101	TCP	42	33033 → 8649 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
4019	0.606813…	192.168.50.101	192.168.50.100	TCP	60	3809 → 33033 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
4020	0.607077…	192.168.50.100	192.168.50.101	IPv4	42	Fragmented IP protocol (proto=TCP 6, off=0, ID=0737) [Reassembled in #4023]
4021	0.607183…	192.168.50.101	192.168.50.100	TCP	60	2135 → 33033 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
4022	0.607221…	192.168.50.100	192.168.50.101	IPv4	42	Fragmented IP protocol (proto=TCP 6, off=8, ID=0737) [Reassembled in #4023]
4023	0.607338…	192.168.50.100	192.168.50.101	TCP	42	33033 → 515 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
4024	0.607437…	192.168.50.101	192.168.50.100	TCP	60	8649 → 33033 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
4025	0.608190…	192.168.50.101	192.168.50.100	TCP	60	515 → 33033 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
4028	154.0577…	192.168.50.101	192.168.50.255	BROW…	286	Local Master Announcement METASPLOITABLE, Workstation, Server, Print Queue
4029	154.0582…	192.168.50.101	192.168.50.255	BROW…	257	Domain/Workgroup Announcement WORKGROUP, NT Workstation, Domain Enum

La frammentazione non contenendo tutte le informazioni , per esempio il numero di porta, può utilizzare uno “state entry” già autorizzato nella prima parte del pacchetto, per saltare un eventuale filtro su quella specifica porta